

to penetrate the site. If the network and host are fully secured, your Web application is the next target for attack. An attacker's easiest entry to an application is through the same 'gate' that legitimate users pass—the application's login page, or a page that does not require authentication.

3. **Escalate privileges (try to gain administrative privileges):** After attackers compromise an application or network, they immediately attempt to gain administrative privileges to take over the server itself. Using least-privileged service accounts throughout your application is a primary defensive feature.
4. **Maintain access and privileges:** Having gained access to a system, attackers try to ensure future access and to cover their tracks. To retain administrative privileges, attackers commonly plant back-door programs or use an existing account that lacks strong protection.
5. **Cover their tracks by clearing logs:** Since system logs will reveal unauthorised access to the system, attackers typically clear audit logs of tell-tale signs, and hide their tools and other evidence of their access. Your log files should be secured (preferably, by regularly copying them to a remote system), and should be analysed regularly. This analysis can sometimes reveal an attempted break-in before damage is done.
6. **Steal information and distribute malware:** Attackers usually try to install programs that may steal confidential information or attack other computers. They may also set up the site to distribute malicious software to visitors who trust the site not to serve them malicious software.
7. **Deny service:** Attackers who cannot gain access may mount a denial of service attack to harass the site owner by preventing legitimate users from connecting to the site. The sheer variety of Web threats and attacks makes it impossible to explain all of them; we have merely looked at a brief outline.

To prevent website falling prey to attackers, your IT team needs to audit your websites for vulnerabilities corresponding to your Web server platform and software. The audit frequency should be every three months, at least, besides immediately after a new vulnerability is reported. Free newsletters from CERT/SANS provide updates about such vulnerabilities from time to time.

You can block attacks by disabling relevant services or patching application code, until the software vendor provides an update that closes the vulnerability. Further, vendors need to pay attention to the website's design and code, and check whether there are potential entry-points for attackers.

You should also ensure a few very basic—but very important—points:

1. Change default login name
2. Change default password
3. Only use encrypted interface to authenticate yourself to the website (HTTPS/SSH)
4. Make sure the password consists of upper/lower-case alphabets, numbers and special characters.

The Nikto advantage

As a website vulnerability scanning tool, Nikto plays a

vital role in keeping your site safe. It can be used very effectively to identify flaws in the design and development of the website, and as an assessment tool to detect possible vulnerabilities in the website. In case of an exploited website, it can also be used to identify the attackers' entry point, as Kedar did for Shree's site.

Important Nikto command line options include:

- **-Cgidir:** Scans the specified CGI directories; could also be special keywords *all* or *none*.
 - **-dbcheck:** Checks the scan databases for syntax errors.
 - **-findonly:** Only discovers and attempts to connect to HTTP(S) ports, does not perform a security scan. Reports the server header.
 - **-host:** Specifies the host(s) to scan
 - **-id:** Specifies basic host authentication in *id:password* format
 - **-port:** TCP port(s) to scan; comma-separated list (80, 443, 8080) or port range (80-90)
 - **-update:** Updates the plug-ins and databases from cirt.net.
- Other command-line options let you fine-tune the scan, including:
- **-mutate:** to combine tests and to guess values. Under the mutate commands, various parameters can be provided to guess common password file names, guess common file extensions, try to discover valid user names by using Apache exploits if *UserDir* set-up is misconfigured, exploit flaws in *cgiwrap* to discover valid user names, and more.
 - **-tuning:** Tunes the scan tests used against a target.
 - **-Format:** Specifies the output file format: TXT, HTML, XML or CSV.

See the documentation for more information on these topics, and other options.

Nikto's configuration file is typically */etc/nikto.conf*. You can set commonly-used settings in this file, to cut down on the length of command lines for each scan. See the documentation for more information.

Nikto can also be integrated with Nessus and openVAS, two of the best vulnerability scanners available.

Now, returning to Shree, whose site had suffered the attack—he was amazed at the technical complexities of what he had thought was the simple Internet, but was grateful to Kedar for the quick and decisive solution to the problem. At Kedar's instruction, Shree modified his company's security policy to include a monthly Nikto scan of the website for vulnerabilities. Shree is a happy person again, since his website is running well, and he hopes Nikto will help him stay ahead of the bad guys! 

References

- Nikto home page: <http://cirt.net/nikto2>
- Open Source Vulnerability DataBase: <http://osvdb.org/>

By: Rajesh M. Deodhar

The author is a BE in industrial electronics as well as a certified information systems auditor. He has more than 15 years of experience in the field of computer hardware, networking and firewalls. He is a director at Omega Systems and Services Pvt Ltd, Pune, and can be contacted at rajesh@isa-ipcop@yahoo.com.